TEHNIČKI PREGLED · STANJE: 31. OKTOBAR 2026

Fortinet FortiGate u enterprise okruženju

Fizička i logička arhitektura, NGFW tehnologije, koliko je često meta napada i kako izgleda proces patchovanja.

FortiOS 7.4 · 7.6 · 8.0 | HA · segmentacija · ZTNA · SD-WAN | CISA KEV · Fortinet PSIRT | Patch SLA i kontrolna lista

Ukratko

1 Najrasprostranjeniji — i među najnapadanijima
Fortinet navodi ≈55 % svetskih isporuka firewall uređaja. U CISA KEV katalogu ima 32 aktivno eksploatisane ranjivosti, od toga 21 u FortiOS-u. Godina 2026. je rekordna: 9 novih unosa do kraja oktobra.

2 Napadaju se interfejsi izloženi internetu
14 od 21 FortiOS ranjivosti iz KEV-a pogađa SSL-VPN ili management ravan (admin GUI, FGFM, CAPWAP, FortiCloud SSO). Dobra arhitektura uklanja te površine sa interneta.

3 Fizički: dva HA sloja i OOB
FGCP active-passive klaster na Internet edge-u i zaseban za DC/ISFW, dva heartbeat linka, LACP ka paru core switch-eva i izolovana OOB management mreža. Kapacitet se računa po Threat Protection i SSL brojkama.

4 Logički: segmentacija i identitet
Zone, default deny i politike po korisnicima i grupama; ISFW između korisnika, servera i OT-a; IPsec IKEv2 ili ZTNA sa MFA umesto SSL-VPN-a; centralno FortiManager i FortiAnalyzer.

5 NGFW: slojevi na granicama poverenja
IPS, Application Control, antimalver, web/DNS filter i SSL deep inspection kao osnova. Na edge-u još inline sandbox, DLP i CASB (FortiGuard Enterprise paket).

6 Patch: dve brzine
Mesečni PSIRT ciklus (drugi utorak) i vanredne zakrpe. Za aktivno eksploatisano i izloženo: mitigacija ≤ 24 h, zakrpa ≤ 72 h, zatim provera kompromitacije. Trenutni minimum: 7.4.13 / 7.6.8 / 8.0.2.

01 Fortinet ukratko str. 2
02 Fizički dizajn str. 3
03 Logički dizajn str. 4
04 NGFW tehnologije str. 6
05 Koliko je često meta str. 7
06 Patch proces str. 8
07 Referentni setup i kontrolna lista str. 10

Nezavisan tehnički pregled zasnovan na javno dostupnim izvorima (Fortinet dokumentacija i PSIRT, CISA KEV, izveštaji istraživača); nije zvaničan Fortinet materijal. Pre izmena u produkciji proverite aktuelne release notes, PSIRT advisory-je i datasheet-ove.

01

SEKCIJA 01 · KONTEKST

Fortinet ukratko

Fortinet (osnovan 2000, sedište Sunnyvale, Kalifornija) gradi celu platformu oko jednog operativnog sistema — FortiOS — i sopstvenih ASIC čipova. FortiGate je centar te platforme, koju Fortinet zove Security Fabric.

Prihod 2025
6,80 mlrd $
+14 % u odnosu na 2024; plan za 2026: 7,5–7,7 mlrd $

Udeo u isporukama
≈55 %
firewall uređaja po broju jedinica (podatak Fortineta)

Gartner MQ 2025
Leader
Hybrid Mesh Firewall (prvo izdanje) i SASE platforme

Grane FortiOS-a
7.4 · 7.6 · 8.0
8.0 je GA od aprila 2026; 7.2 je van podrške

Šta je FortiGate

Next-generation firewall koji u jednom uređaju i jednom OS-u objedinjuje stateful firewall, IPS, kontrolu aplikacija, web i DNS filtriranje, antimalver, VPN i ZTNA, SD-WAN, kao i kontroler za FortiSwitch i FortiAP (FortiLink). Isti FortiOS radi od filijalskog 50G do šasija serije 7000 i virtuelnih instanci u AWS-u, Azure-u i GCP-u, pa se politike, alati i znanje prenose kroz celu mrežu.

HARDVERSKO UBRZANJE (SPU)

- **NP7** (Network Processor) — offload firewall sesija, NAT-a, IPsec-a i VXLAN-a; osnova DC i velikih edge modela.
- **CP** (Content Processor, npr. CP9) — ubrzava IPS/antivirus pretragu obrazaca i TLS kriptografiju.
- **SP5** (SoC u G-seriji) — spaja mrežne i sadržajne funkcije za kampus i filijale (npr. 50G, 70G, 90G).

Posledica za dizajn: performanse zavise od toga da li saobraćaj ide kroz ASIC. Proxy inspekcija i deo funkcija rade na CPU-u, zato se kapacitet uvek proverava sa uključenim profilima.

Security Fabric oko FortiGate-a

Mreža	FortiGate · FortiSwitch · FortiAP · FortiExtender (LTE/5G) · FortiNAC
Identitet i pristup	FortiAuthenticator · FortiToken · FortiClient + EMS · FortiPAM
Upravljanje i SOC	FortiManager · FortiAnalyzer · FortiSIEM · FortiSOAR · FortiEDR
Aplikacije i sadržaj	FortiWeb (WAF) · FortiMail · FortiSandbox · FortiDLP
Cloud i SASE	FortiGate-VM · FortiSASE · FortiCNAPP

FORTIOS 8.0 — ŠTA JE NOVO (GA APRIL 2026)

- Vidljivost i kontrola upotrebe AI alata (shadow AI, AI-aware kontrola aplikacija).
- Post-kvantna kriptografija: hibridna razmena ključeva u SSL deep inspection-u, PQC sertifikati (ML-DSA) za admin pristup i agentless VPN.
- Multipath IPsec tuneli, objedinjeni SD-WAN paketi, SASE Outpost i suvereni SASE.

Za produkciju ostaju zrele grane 7.4 / 7.6 dok 8.0 ne postane „Recommended Release" za vaš model.

Licenciranje: FortiGuard paketi

Paket	Sadrži	Gde ima smisla
ATP — Advanced Threat Protection	IPS, antimalver (AV, botnet), Application Control, FortiCare Premium	DC / ISFW, interni segmenti
UTP — Unified Threat Protection	ATP + URL, DNS i video filtriranje, antispam	filijale, manji edge
Enterprise Protection	UTP + AI-based inline malware prevention (inline sandbox), DLP, inline CASB, Attack Surface Security	Internet edge, kampus

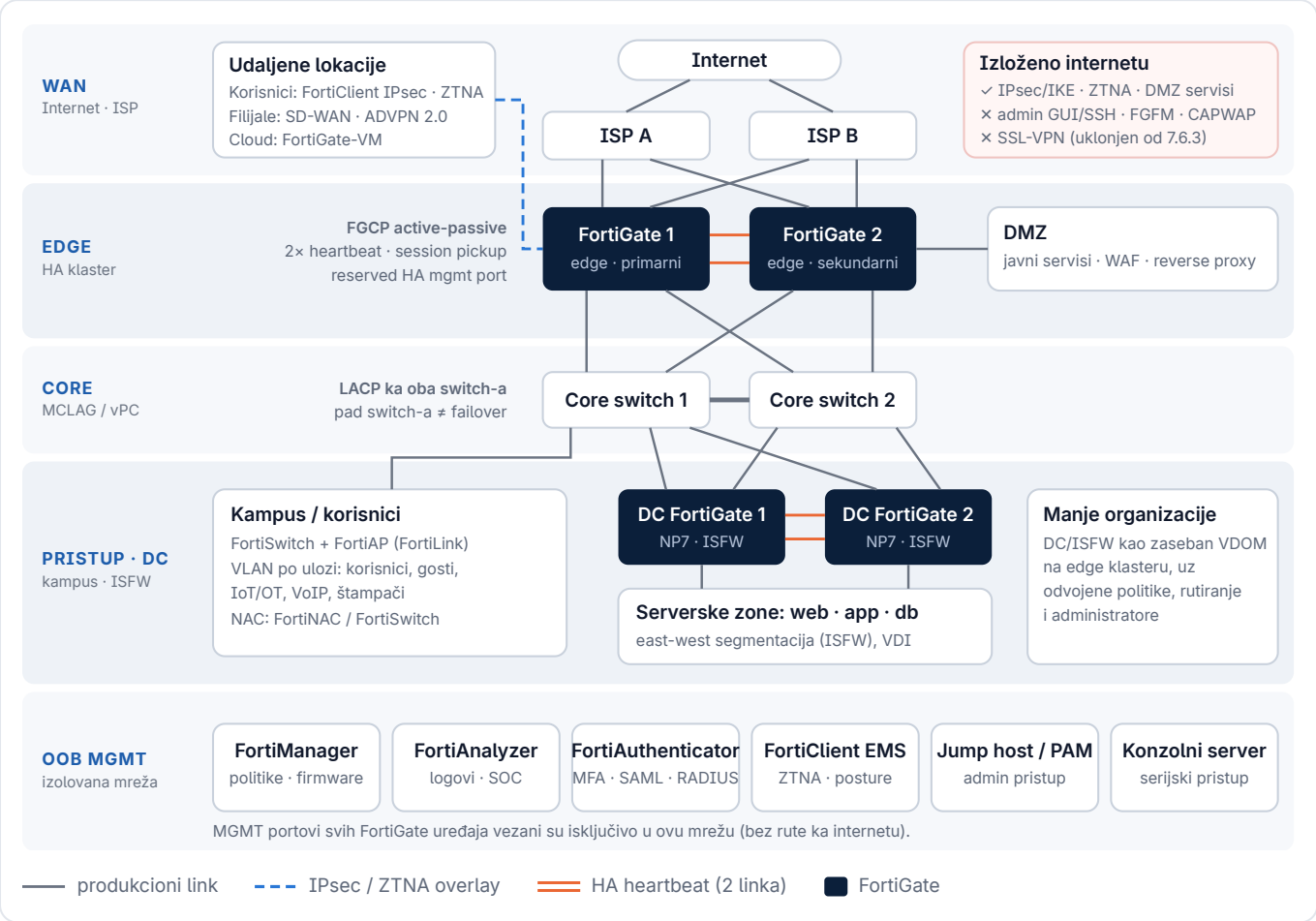
Bez važeće FortiGuard pretplate nema novih potpisa — IPS, antivirus i web filter brzo gube vrednost. Planirajte obnovu licenci zajedno sa hardverskim ciklusom.

02

SEKCIJA 02 · ARHITEKTURA

Fizički dizajn

Cilj: nijedna pojedinačna komponenta — uređaj, link, switch, napajanje ili ISP — ne sme da prekine saobraćaj, a upravljanje mora da radi i kada produkciona mreža ne radi.



Slika 1. Referentna topologija: odvojeni HA klasteri za Internet edge i DC/ISFW, dual-homing ka core paru i izolovana OOB management mreža.

VISOKA DOSTUPNOST (HA)

- **FGCP active-passive** par istog modela, firmvera i licenci na svakom kritičnom sloju. Active-active deli samo sesije sa security profilima i retko vredi dodatne složenosti.
- **Dva heartbeat linka**, direktno kablirana, na različitim portovima (namenski HA1/HA2 gde postoje) — nikad preko istog switch-a kao produkcija.
- **Session pickup** (uključujući UDP/ICMP), *monitor* interfejsi i *link-monitor* ka ISP gateway-ima, da bi failover reagovao i na pad upstream-a.
- **Reserved HA management** interfejs: svakom članu se pristupa zasebno (monitoring, upgrade, troubleshooting).

KABLOVI, NAPAJANJE, UPRAVLJANJE

- Svaki FortiGate je **dual-homed (LACP)** ka paru core switch-eva (MCLAG/vPC) — pad switch-a ne izaziva failover firewall-a.
- **Dva napajanja** na odvojene PDU/UPS grane; članovi klastera u različitim rack-ovima ili salama.
- **OOB management**: MGMT portovi u izolovanu mrežu + konzolni server za serijski pristup kada ništa drugo ne radi.
- **Odvojeni slojevi**: Internet edge i DC/ISFW su posebni klasteri (ili bar posebni VDOM-ovi) — greška ili kompromitacija edge-a ne otvara DC.
- **Podrška**: FortiCare Premium/Elite (24×7, RMA) i hladna rezerva za filijale.

ČESTA GREŠKA

Heartbeat linkovi kroz jedan switch bez redundanse: kada on padne, nastaje **split-brain** — oba člana postaju primarni, sa istim IP i MAC adresama, i mreža staje.

Dimenzionisanje i izbor modela

Uloga	Tipični modeli*	Ključni zahtevi	FortiGuard
Filijala / SD-WAN	50G, 70G, 90G (ranije 40F, 60F)	SD-WAN + ADVPN, LTE/5G rezerva, FortiLink	UTP
Kampus / srednji edge	120G, 200F, 400G, 600F	deep inspection, ZTNA/VPN, Wi-Fi kontroler	Enterprise
Internet edge	900G, 1000F, 1800F, 2600F	dual ISP, DMZ, SSL inspekcija, VPN/SD-WAN hub	Enterprise
DC / ISFW / core	3500G, 3700F, 4200F, 4800F	NP7, 100G+, east-west IPS, VXLAN, visok CPS	ATP
Cloud	FortiGate-VM (AWS, Azure, GCP…)	HA preko cloud LB-a, SDN konektori, autoscale	po potrebi

* Orijentaciono. Konačan izbor po zvaničnom datasheet-u i POC testu sa realnim saobraćajem.

PRAVILA DIMENZIONISANJA

1. Računajte po **Threat Protection** i **SSL Inspection** throughput-u, ne po „Firewall throughput"-u: sa uključenim IPS + AppCtrl + AV i dešifrovanjem kapacitet je često više od 10× manji.
2. Ciljajte **≤ 50–60 % opterećenja** u špicu posle 3–5 godina rasta.
3. Proverite i broj sesija, nove sesije/s, IPsec tunele, broj VPN/ZTNA korisnika i log rate ka FortiAnalyzer-u.
4. Jedan član HA para mora sam da nosi ceo saobraćaj — active-active nije zamena za dimenzionisanje.
5. POC sa realnim saobraćajem i uključenim profilima pre kupovine.

Provera klastera: `get system ha status` i `diagnose sys ha checksum cluster` (checksum-ovi članova moraju biti isti).

HA osnova — primer konfiguracije (FGCP A-P)

```
config system ha
    set group-name "EDGE-HA"
    set group-id 10
    set mode a-p
    set password <tajna>
    set hbdev "ha1" 100 "ha2" 50
    set session-pickup enable
    set session-pickup-connectionless enable
    set override disable
    set priority 200          # 100 na sekundarnom
    set monitor "x1" "x2"     # LACP ka core-u
    set ha-mgmt-status enable
    config ha-mgmt-interfaces
        edit 1
            set interface "mgmt"
            set gateway 10.99.0.1
        next
    end
end
```

03 SEKCIJA 03 · ARHITEKTURA
Logički dizajn

Fizička redundansa ne pomaže ako je mreža logički „ravna". Cilj je da kompromitacija jednog segmenta ostane u tom segmentu, a da administracija uređaja bude nedostupna napadaču.

Zone i dozvoljeni tokovi — primer matrice

Izvor ↓ / Odredište →	Internet	DMZ	DC / serveri	Korisnici	MGMT
Korisnici	✓ pun NGFW	◐ HTTPS	◐ po aplikaciji	× intrazone	×
Gosti	✓ web / DNS	×	×	×	×
IoT / OT	◐ allow-list	×	◐ OT IPS	×	×
VPN / ZTNA	◐ po politici	◐	◐ po grupi	×	×
DMZ	◐ update	× intrazone	◐ app → db	×	×
DC / serveri	◐ preko proxy-ja	◐	◐ east-west IPS	×	×
Internet	—	◐ samo objavljeni	×	×	×
MGMT (jump / PAM)	◐ update	◐ admin	◐ admin	◐ admin	—

✓ dozvoljeno uz pun NGFW profil ◐ samo navedeni servisi, aplikacije ili grupe × default deny (logovano)

PRINCIPI ZA POLITIKE

1. **Default deny**: poslednje pravilo je eksplicitni *deny all* sa logovanjem.
2. **Least privilege**: konkretni izvori, odredišta i servisi; „all/ALL" samo ka internetu i uz pun NGFW profil.
3. **Identitet umesto IP adresa**: grupe iz AD / Entra ID (FSSO, SAML) u politikama; stanje uređaja preko FortiClient EMS tagova.
4. **ISDB objekti** (Internet Service Database) za SaaS kao što su M365 ili Zoom, umesto ručnih IP lista.
5. **Dokumentacija**: konvencija naziva, komentar sa brojem tiketa i vlasnikom pravila.
6. **Higijena**: kvartalni pregled *hit count* / *last used*, uklanjanje nekorišćenih i preklapajućih pravila.
7. **Promene kroz FortiManager**: workflow sa odobravanjem, revizije i rollback.

GRADIVNI BLOKOVI FORTIOS-A

- **Zone** grupišu interfejse/VLAN-ove istog nivoa poverenja (manje pravila); `set intrazone deny` sprečava lateralno kretanje unutar zone.
- **VDOM** je potpuno odvojen „virtuelni firewall" (politike, rutiranje, administratori), npr. INET, DC i OT; management VDOM služi samo za upravljanje.
- **VRF** daje odvojene tabele rutiranja unutar istog VDOM-a (gosti, partneri, preklapajući opsezi).
- **Profile-based ili NGFW policy-based mode**: profile-based je standard i najčešći izbor; policy-based kada želite pravila direktno po aplikacijama i URL kategorijama.
- **Central SNAT i VIP objekti** odvajaju NAT od bezbednosnih politika, što olakšava velike rulebase-ove.

Zaštita management ravni — najvažnija pojedinačna mera

> Većina masovnih kompromitacija FortiGate-a počinje od management interfejsa dostupnog sa interneta: CVE-2022-40684, CVE-2024-55591, FortiCloud SSO (2025/26) i kampanja sa 600+ uređaja iz 2026. koja nije koristila nijednu ranjivost, samo slabe lozinke.

- Admin HTTPS/SSH, FGFM (TCP 541) i CAPWAP (UDP 5246/5247) **nikad na WAN interfejsima**; pristup samo iz MGMT mreže ili jump hosta (*trusted hosts* + *local-in* politike).
- **MFA za sve admin naloge** (FortiToken, FortiAuthenticator ili SAML), RBAC profili, bez deljenih naloga; podrazumevani `admin` preimenovati ili onemogućiti.
- **FortiCloud SSO login isključiti** ako se ne koristi (CVE-2025-59718, CVE-2026-24858).
- **private-data-encryption** za tajne u konfiguraciji — CVE-2019-6693 (fiksni ključ za backup) je u KEV-u od 2025.
- TLS 1.2/1.3, zaključavanje posle neuspelih prijava, SNMPv3, NTP, login banner; isključiti sve servise koji se ne koriste.

```
config system global
    set admin-forticloud-sso-login disable
    set private-data-encryption enable
    set admin-lockout-threshold 3
    set admin-lockout-duration 900
    set admin-https-ssl-versions tlsv1-2 tlsv1-3
    set strong-crypto enable
end
config system interface
    edit "wan1"
        set allowaccess ping    # bez https/ssh/fgfm
    next
end
config system admin
    edit "adm.petar.petrovic"
        set trusthost1 10.99.0.0 255.255.255.0
        set two-factor fortitoken
    next
end
```

UDALJENI PRISTUP

SSL-VPN tunnel mode je **uklonjen u FortiOS 7.6.3**. Zamena je **IPsec IKEv2** (FortiClient, po potrebi preko TCP/443) uz SAML MFA, a za pristup aplikacijama **ZTNA** sa proverom stanja uređaja (EMS). Agentless VPN (bivši web mode) samo ako je neophodan; nije podržan na 40F, 60F i 90G.

SD-WAN I FILIJALE

Hub-and-spoke IPsec overlay sa **ADVPN 2.0** (dinamički spoke-to-spoke tuneli), BGP na loopback adresama, dva huba (DC1/DC2), performance SLA (latency, jitter, gubitak paketa) i pravila po aplikaciji. Lokalni internet breakout samo uz pun NGFW profil ili FortiSASE.

LOGOVANJE I NADZOR

FortiAnalyzer (HA) ili SIEM preko syslog-a/TLS-a. Logovati deny, security i admin događaje (prijave, izmene konfiguracije, novi admin nalozi); NTP; čuvanje ≥ 12 meseci. *Automation stitches*: alarm na prijavu sa nepoznate IP adrese, novi admin nalog i HA failover.

04

SEKCIJA 04 · ZAŠTITA

NGFW tehnologije koje treba koristiti

Vrednost NGFW-a nije u pravilu „dozvoli port 443", već u slojevima inspekcije uključenim na granicama poverenja. Tabela daje preporučenu osnovnu konfiguraciju za enterprise.

Tehnologija	Šta radi	Preporuka za enterprise
Application Control	L7 prepoznavanje aplikacija, nezavisno od porta	Blokirati rizične kategorije (P2P, proxy i anonimizatori, neodobreni remote-access); allow-list na serverskim segmentima.
IPS	Potpisi i anomalije protokola; „virtual patching"	Odvojeni klijentski i serverski profili; blokirati Critical/High i botnet C&C; OT potpisi za industrijske segmente.
Antimalver	FortiGuard AV, AI/ML detekcija, Outbreak Prevention	Na svim politikama ka internetu i između zona; inline sandbox na edge-u; FortiSandbox za sumnjive fajlove.
Web filter	URL kategorije i reputacija	Blokirati malicious, phishing, newly observed/registered i unrated; Safe Search; pravila po grupama.
DNS filter	Blokada malicioznih, C2 i DGA domena	Na svim izlaznim politikama i za interni DNS; kontrolisati DoH/DoT ka nepoznatim resolverima.
SSL/TLS deep inspection	Dešifruje saobraćaj da bi ostali slojevi videli sadržaj	Full inspection za korisnike (CA preko GPO/MDM); izuzeci: bankarstvo, zdravlje, pinning; gosti samo certificate inspection.
File filter i DLP	Tipovi fajlova; FortiGuard DLP servis	Blokirati izvršne fajlove sa rizičnih kategorija; DLP za lične i finansijske podatke.
Inline CASB	Kontrola SaaS aplikacija i tenanta	Dozvoliti samo korporativni M365/Google tenant; vidljivost shadow IT i shadow AI.
ZTNA i identitet	Pristup po korisniku i stanju uređaja (FSSO, SAML, EMS)	ZTNA umesto VPN-a za web, RDP i SSH aplikacije; politike po grupama; MFA svuda.
Reputacija i CTI	IP reputacija, ISDB, spoljni IoC feed-ovi	Blokirati maliciozne IP adrese i anonimizere; uvesti CTI feed-ove (IP, domen, URL).

Gde se šta uključuje — preporuka po toku saobraćaja

Tok saobraćaja	App Control	IPS	Antimalver	Web / DNS	SSL deep	DLP / CASB
Korisnici → Internet	●	●	●	●	●	◐
Gosti → Internet	●	●	◐	●	— samo cert. inspection	—
Internet → DMZ	◐	● serverski profil	●	—	● ili na WAF-u	—
Korisnici → DC	●	●	●	—	◐	◐
DC ↔ DC (east-west)	● allow-list	● virtual patching	◐	—	◐	—
IoT / OT segmenti	● OT protokoli	● OT potpisi	◐	● DNS	—	—
VPN / ZTNA → interno	●	●	●	◐	◐	◐

● uključiti ◐ po potrebi (rizik, licenca, privatnost) — nije potrebno

FLOW ILI PROXY INSPEKCIJA?

Flow-based (podrazumevano) je najbrži i koristi hardversko ubrzanje. **Proxy-based** samo gde treba CDR, puno baferovanje fajlova ili napredne web/email funkcije.

SSL INSPEKCIJA BEZ IZNENAĐENJA

Pilot grupa, CA sertifikat distribuiran unapred, dokumentovani izuzeci (privatnost, pinning). Bez dešifrovanja IPS, antimalver i DLP vide samo metapodatke.

05

SEKCIJA 05 · PRETNJE

Koliko je FortiGate često meta

Kratko: veoma često. FortiGate je najrasprostranjeniji firewall i stoji direktno na internetu, što ga čini idealnom metom za državne aktere, ransomware grupe i brokere inicijalnog pristupa.

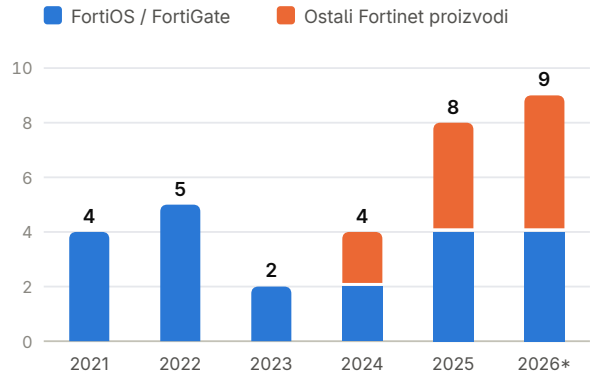
Fortinet unosa u CISA KEV
32
deli 9.–10. mesto od svih proizvođača (1.766 unosa ukupno)

Od toga pogađa FortiOS
21
FortiGate je glavna meta unutar Fortinet portfolija

Novih KEV unosa u 2026.
9
rekord (2025: 8); stanje na dan 30.10.2026.

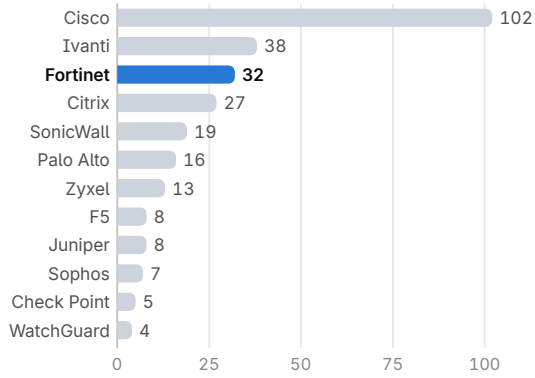
Rok u KEV-u (2026.)
3 dana
za 8 od 9 unosa (2025: 7–21 dan)

FORTINET U CISA KEV, PO GODINI



KEV katalog postoji od novembra 2021, pa 2021. uključuje i starije CVE-ove. *2026 = do 30.10.2026. Ostali proizvodi: EMS, FortiManager, FortiWeb, FortiSandbox, FortiMail, FortiVoice i dr.

KEV UNOSI PO PROIZVOĐAČU (EDGE)



Proizvođači mrežne i edge bezbednosti; broj unosa za sve proizvode proizvođača (Cisco i Ivanti imaju širi portfolio). Izvor: CISA KEV, verzija 2026.10.30.

GDE SU FORTIOS RANJIVOSTI IZ KEV-A (21)



Dve trećine (14 od 21) su na interfejsima koji su tipično izloženi internetu — direktan argument za arhitekturu bez SSL-VPN-a i bez management pristupa sa WAN-a.

Obrasci koji se ponavljaju

1. **SSL-VPN** je bio najveća pojedinačna površina napada — Fortinet je u 7.6.3 uklonio tunnel mode.
2. **Izložen management = otvorena vrata**, sa CVE-om i bez njega (slabe lozinke, FortiCloud SSO).
3. **Zakrpa ≠ čist uređaj**: COATHANGER i symlink preživljavaju upgrade, pa je potrebna provera kompromitacije.
4. **Brzina**: veliki deo ranjivosti eksploatisan je kao zero-day ili za nekoliko dana — mitigacija mora da postoji pre zakrpe.
5. **Meta je ceo Fabric**: svih 11 KEV unosa za druge Fortinet proizvode (EMS, FortiWeb, FortiSandbox, FortiManager, FortiMail…) dodato je od 2024.
6. **Akteri**: državni akteri (npr. Volt Typhoon, UNC3886, kampanja COATHANGER), ransomware grupe (14 od 32 Fortinet KEV unosa ima oznaku ransomware upotrebe) i brokeri inicijalnog pristupa.

Najvažniji incidenti 2021–2026

09/2021 — Objavljeni kredencijali sa **~87.000** SSL-VPN uređaja (CVE-2018-13379, zakrpljen još 2019) — nezakrpljeni uređaji i nepromenjene lozinke.

10/2022 — CVE-2022-40684 (zaobilaženje admin autentifikacije); 2025. grupa „Belsen" objavljuje konfiguracije i VPN kredencijale sa **15.000+** uređaja.

12/2022 — CVE-2022-42475 (SSL-VPN, zero-day) → kineska kampanja **COATHANGER**: prema holandskom MIVD-u najmanje 20.000 FortiGate sistema za nekoliko meseci; malver preživljava reboot i upgrade.

02/2024 — CVE-2024-21762 (SSL-VPN, RCE): mesec dana posle zakrpe **~150.000** izloženih uređaja i dalje ranjivo (Shadowserver).

01/2025 — CVE-2024-55591: preuzimanje super-admin naloga preko management interfejsa; eksploatisan kao zero-day od novembra 2024.

04/2025 — Symlink perzistencija: napadači zadržali read-only pristup i posle zakrpe na **16.620** uređaja (Shadowserver).

12/2025 – 01/2026 — FortiCloud SSO: CVE-2025-59718 eksploatisan za nekoliko dana, zatim zero-day CVE-2026-24858; Fortinet privremeno blokira SSO sa ranjivih verzija.

01–02/2026 — Amazon: AI-potpomognut napadač kompromitovao **600+** FortiGate uređaja u 55 zemalja — bez ijednog CVE-a, preko izloženog managementa i slabih lozinki bez MFA.

07–09/2026 — CVE-2025-25249 (CAPWAP, `cw_acd`) → Node.js RAT „PivotC2" na FortiGate-u; CVE-2025-68686 zaobilazi zakrpu za symlink perzistenciju.

10/2026 — Fortinet „Security Hardening" izdanje (8.0.2 / 7.6.8 / 7.4.13 / 7.2.14) sa ispravkama iz AI-potpomognutog testiranja; CVE detalji najavljeni za 10.11.2026.

Puna tačka = zero-day ili eksploatacija pre ili neposredno posle objave zakrpe.

SEKCIJA 06 · OPERACIJE

06 Kako ide proces patchovanja

Fortinet zakrpe isporučuje kao nove patch verzije FortiOS-a (npr. 7.6.7 → 7.6.8). Proces mora da pokrije dve brzine: redovan mesečni ritam i hitnu reakciju na aktivno eksploatisane ranjivosti.

KAKO FORTINET OBJAVLJUJE RANJIVOSTI I ZAKRPE

- **PSIRT ritam**: advisory-ji izlaze mesečno, **drugog utorka u mesecu** (13.10.2026; sledeći 10.11.2026), a kritične i aktivno eksploatisane ranjivosti vanredno (out-of-band). FG-IR advisory sadrži pogođene verzije, CVSS, rešenje, workaround i često IoC.
- **Grane i build-ovi**: svaka major grana (7.4, 7.6, 8.0) dobija patch verzije označene kao *Feature* ili *Mature*. „Recommended Release" po modelu (ažurira se kvartalno) je polazna tačka za produkciju.
- **Privatna obaveštenja**: Fortinet ponekad unapred obaveštava korisnike — registracija uređaja i kontakti na support portalu moraju biti ažurni.
- **Životni ciklus**: standardno ~36 meseci inženjerske podrške (EoES) i ~54 meseca do End of Support od GA; u martu 2026. (CSB-260330-1) rokovi za 7.4 i 7.6 produženi su za godinu dana.
- **Automatski upgrade**: od 7.4.5 / 7.6.1 podrazumevano uključen za patch verzije (osim za Fabric članove, uređaje pod FortiManager-om i sekundarne HA članove; kašnjenje 3 dana). U enterprise okruženju upgrade kontrolišite preko FortiManager-a.

Grana	GA	Status (oktobar 2026)	End of Support	Preporuka
7.2	mar 2022	van podrške (7.2.14 iz oktobra je izuzetak)	30.09.2026	migrirati odmah na 7.4 / 7.6
7.4	maj 2023	aktivno održavana · minimum 7.4.13	11.11.2028	konzervativan izbor za produkciju
7.6	jul 2024	aktivno održavana · minimum 7.6.8	25.01.2030	cilj za većinu novih implementacija
8.0	apr 2026	najnovija grana · minimum 8.0.2	nije objavljen (~54 mes. od GA)	lab i pilot, dok ne postane Recommended

AKTUELNO · OKTOBAR 2026

Fortinet je 21–22.10.2026. objavio **Security Hardening** izdanja — FortiOS **8.0.2 / 7.6.8 / 7.4.13 / 7.2.14**, FortiManager i FortiAnalyzer 7.4.12 / 7.2.13 — sa kritičnim i visokim ispravkama pronađenim AI-potpomognutim testiranjem. CVE oznake i detalji najavljeni su za **10.11.2026**. Preporuka: planirati upgrade odmah, prvo uređaji izloženi internetu.

Proces u 8 koraka

1 Praćenje
PSIRT (fortiguard.com/psirt, RSS, e-mail), CISA KEV, FortiGuard Outbreak Alerts, nacionalni CERT.

2 Trijaža (≤ 24 h)
Da li su verzija i model pogođeni? Da li je ranjiva funkcija uključena i izložena? Ima li eksploatacije (KEV)? → prioritet P0–P3.

3 Hitna mitigacija
Workaround iz advisory-ja: isključiti funkciju, local-in politike i trusted hosts, IPS potpis (virtual patch), blokada izvora.

4 Izbor verzije
Najniži build koji ispravlja CVE i jeste Recommended/Mature; release notes; Upgrade Path Tool; kompatibilnost FMG/FAZ/EMS/FortiSwitch/FortiAP.

5 Priprema i test
Šifrovan backup konfiguracije, provera hash-a image-a, lab ili „kanarinac" lokacija niskog rizika, plan povratka.

6 Rollout
Prvo internet-izloženi uređaji. Redosled u Fabric-u: FAZ → FMG → FortiGate → FortiSwitch/FortiAP → EMS/FortiClient; HA bez prekida.

7 Verifikacija
Verzija, HA sinhronizacija, rutiranje/BGP, VPN i SD-WAN SLA, logovi u FAZ, FortiGuard update, kritične aplikacije.

8 Provera kompromitacije
IoC iz advisory-ja, nepoznati admin nalozi, izmene konfiguracije, sumnjivi fajlovi. Ako je uređaj kompromitovan: čista instalacija i rotacija svih tajni.

Rokovi (SLA) — predlog interne politike

Prioritet	Kriterijum	Mitigacija	Zakrpa
P0 · hitno	Aktivno eksploatisano (KEV / Fortinet) i ranjiva funkcija izložena internetu	odmah, ≤ 24 h	≤ 72 h
P1 · kritično	CVSS ≥ 9 bez eksploatacije, ili eksploatisano a nije izloženo	≤ 72 h	≤ 7 dana
P2 · visoko	CVSS 7,0–8,9	po potrebi	≤ 30 dana (mesečni prozor)
P3 · srednje/nisko	CVSS < 7	—	≤ 90 dana (kvartalni ciklus)
Major grana	Prelazak na novu granu (npr. 7.4 → 7.6)	—	svakih ~18–24 meseca, pre EoES

Referenca: CISA BOD 26-04 (jun 2026) određuje rokove po riziku (izloženost, KEV, automatizovanost eksploatacije, uticaj), najkraći 3 dana; za Fortinet unose u KEV-u 2026. rok je uglavnom bio 3 dana.

HA UPGRADE BEZ PREKIDA

Uz `uninterruptible-upgrade` (podrazumevano) image se učitava na primarni: prvo se nadograđuju sekundarni, zatim failover i nadogradnja bivšeg primarnog. Uz session pickup prekid je reda sekundi — ipak u servisnom prozoru. Za flotu: FortiManager (firmware šabloni, zakazivanje).

Downgrade ne vraća automatski staru konfiguraciju — za povratak koristite backup napravljen na prethodnoj verziji.

KRATKA PROVERA PRE I POSLE

Pre: backup i revizija u FMG · release notes (special notices, known issues) · upgrade path · konzolni pristup · `diagnose sys ha checksum cluster` · važeće FortiGuard licence.

Posle: `get system status` · `get system ha status` · `get router info routing-table all` · VPN/SD-WAN status · `diagnose autoupdate versions` · logovi stižu u FAZ.

07

SEKCIJA 07 · REZIME

Referentni setup i kontrolna lista

Ceo preporučeni enterprise setup na jednom mestu, i dvadeset kontrola koje pokrivaju najveći deo rizika koji napadači danas zaista eksploatišu.

Sloj	Preporučeno rešenje	Ključne postavke
Internet edge	2× FortiGate 900G–2600F, HA, Enterprise	dual ISP, DMZ, IPsec/ZTNA hub; admin nikad sa WAN-a
DC / ISFW	2× FortiGate NP7 (3500G, 3700F), HA, ATP	zone web/app/db i OT, IPS virtual patching, allow-list
Filijale	FortiGate 50G–90G, UTP	SD-WAN + ADVPN 2.0 ka dva huba, FortiLink switch/AP
Udaljeni pristup	FortiClient + EMS, SAML MFA (Entra ID / FAC)	IPsec IKEv2 + MFA, ZTNA za aplikacije, SSL-VPN ugašen
Upravljanje	FortiManager (HA) u OOB mreži	policy paketi, odobravanje izmena, firmware šabloni
Logovanje i SOC	FortiAnalyzer (HA) → SIEM / SOC	≥ 12 meseci logova, alarmi na admin događaje
Operacije	PSIRT + KEV praćenje, patch SLA	P0 ≤ 72 h, Recommended build na 7.4 / 7.6, IoC provera

Kontrolna lista

ARHITEKTURA

- [ ] HA klaster (FGCP A-P) na edge-u i u DC-u, dva heartbeat linka
- [ ] Dual-homing (LACP) ka core paru i dva napajanja
- [ ] OOB management mreža i konzolni server
- [ ] Dimenzionisano po Threat Protection / SSL kapacitetu (≤ 60 %)
- [ ] Segmentacija po zonama, `intrazone deny`, ISFW za DC i OT

POLITIKE I NGFW

- [ ] Default deny i eksplicitni deny sa logovanjem
- [ ] Politike po identitetu (AD / Entra ID), ISDB za SaaS
- [ ] IPS + AppCtrl + antimalver + web/DNS na svim granicama poverenja
- [ ] SSL deep inspection za korisnike, dokumentovani izuzeci
- [ ] Kvartalni pregled pravila (hit count, last used)

MANAGEMENT RAVAN

- [ ] Bez admin/FGFM/CAPWAP pristupa sa WAN-a; trusted hosts i local-in
- [ ] MFA i RBAC za sve administratore, bez deljenih naloga
- [ ] FortiCloud SSO login isključen ako se ne koristi
- [ ] private-data-encryption uključen, šifrovani backup-ovi
- [ ] SSL-VPN ugašen → IPsec IKEv2 / ZTNA sa MFA

OPERACIJE I PATCH

- [ ] Pretplata na PSIRT i praćenje KEV-a; SLA za P0 ≤ 72 h
- [ ] Recommended/Mature build na podržanoj grani (7.4 / 7.6)
- [ ] Logovi u FortiAnalyzer/SIEM ≥ 12 meseci, alarmi na admin događaje
- [ ] Posle kritičnih CVE-ova: lov na IoC i provera admin naloga
- [ ] FortiManager za promene, revizije i rollout firmvera

Izvori (provereno 30–31.10.2026)

1. **CISA Known Exploited Vulnerabilities**, verzija kataloga 2026.10.30 — github.com/cisagov/kev-data (sve KEV brojke u ovom dokumentu).
2. **Fortinet PSIRT** — fortiguard.com/psirt; PSIRT napomena o mesečnom objavljivanju (drugi utorak) — community.fortinet.com.
3. **Fortinet dokumentacija** — Recommended Release for FortiOS (KB); FortiOS 7.6.3 Release Notes, Special notices (SSL VPN tunnel mode); Automatic firmware upgrade (7.4.5 / 7.6.1); Upgrade Path Tool — docs.fortinet.com/upgrade-tool.
4. **Fortinet** — Technical Tip: FortiOS End of Support change for v7.4 and v7.6 (CSB-260330-1, mart 2026); Product Life Cycle.
5. **Fortinet saopštenja** — FortiOS 8.0 (Accelerate, mart 2026); Q4/FY2025 rezultati (5.2.2026); Leader u Gartner MQ za Hybrid Mesh Firewall (27.8.2025).
6. **Security Hardening izdanje** (21.10.2026) — Canadian Centre for Cyber Security AV26-1081; HKCERT bilten 23.10.2026.
7. **CISA BOD 26-04** „Prioritizing Security Updates Based on Risk" (10.6.2026) — pregledi: SecurityWeek, Tenable.
8. **Amazon Threat Intelligence** — „AI-augmented threat actor accesses FortiGate devices at scale", AWS Security Blog (feb 2026).
9. **MIVD/AIVD i NCSC-NL** — COATHANGER (feb. i jun 2024), preko Help Net Security i The Record.
10. **Shadowserver** (preko BleepingComputer i The Hacker News) — CVE-2024-21762 (mar 2024); symlink perzistencija (apr 2025).
11. **Arctic Wolf / BleepingComputer** — CVE-2026-24858 FortiCloud SSO (jan 2026). **SOCRadar** — CVE-2025-25249 / PivotC2 (2026). **HKCERT, The Record** — curenje kredencijala 2021.

Nezavisan pregled; nije zvaničan Fortinet materijal. Nazivi proizvoda i robne marke pripadaju njihovim vlasnicima. Konfiguracioni primeri su ilustrativni — pre primene ih prilagodite i testirajte u svom okruženju.